

Security Architecture & Zero Trust

What Architecture Is

Security architecture is the *design* of systems so they're safe by construction â€” not "add security later." It answers: "what must be trusted, and how little trust can we get away with?"

The Classic Principles

Defense in depth â€” layers; a failure anywhere isn't a failure everywhere

Least privilege â€” every component only gets what it needs

Fail closed â€” when in doubt, deny

Separation of duties â€” no one person can do harmful alone

Least common mechanism â€” don't share more than required

Economy of mechanism â€” simplicity is security (complexity breeds holes)

Compartmentalization â€” break into blast-radius-cells

Zones as Architecture (the Cisco-to-data-center view)

[Internet] â†’ [DMZ] â†’ [Internal] â†’ [Data Center] â†’ [Trusted/Admin]
each hop = a firewall + a new trust level + a policy change

Data flows (not just network) are the real specifications: what does an app need to communicate with, in which direction, on which ports? That's the allowlist that becomes the firewall rules and the monitoring signature.

Zero Trust: The 2020s Model

"Never trust, always verify." The old model: 'inside the firewall = trusted'. The real model: no implicit trust, every request authenticated & authorized regardless of location:

Identity-driven "every request tied to a user+device"

Micro-segmentation "even East-West traffic is gated"

Continuous verification "posture checks, re-auth, not 'login once'"

Assume breach "monitor, log, minimize blast radius"

The classic "castle and moat" vs "crowded city": every building has its own locks and guards.

Architecture in Practice (a simple case)

Building a web app:

```
User → WAF → LB → App (containers) → DB (private subnet, no internet)
      ↑
      | TLS everywhere
      | least-privilege IAM
      |
      | Secrets in a vault, never in images
      |
      | Logs > SIEM; Alerts on anom traffic
```

Every arrow is a *trust decision* "and the plan should show each decision's control."

The senior skill: the ability to see a system as *trust graph* and answer "what's the minimum set of trust relationships that still works?" That question is architecture.

[← Module start](#)

[Threat Intelligence: Sources, ...](#)